

# Reporte Ejecutivo de Gestión de Riesgos

## Clínica privada — SimpleRisk

Responsable: Maximiliano Díaz LU: 31059979

### Resumen ejecutivo

Se realizó una evaluación de riesgos de seguridad de la información para una clínica privada con aproximadamente 120 empleados y 800 pacientes diarios. La organización depende de sistemas digitales para gestionar historias clínicas, información de seguros y obras sociales y datos de facturación. Se identificaron siete riesgos y se priorizaron mediante la metodología Classic de SimpleRisk.

Los resultados muestran dos riesgos inicialmente clasificados como **High** y un tercer riesgo de protección de datos elevado a **High** para priorizar su tratamiento. El resto de los escenarios quedó clasificado como Medium. La estrategia de tratamiento seleccionada es principalmente la mitigación.

### Top 5 riesgos prioritarios

| Prioridad | Riesgo                                    | Nivel  | Tratamiento |
|-----------|-------------------------------------------|--------|-------------|
| 1         | Ransomware afecta los sistemas clínicos   | High   | Mitigate    |
| 2         | Acceso no autorizado a historias clínicas | High   | Mitigate    |
| 3         | Filtración de datos de pacientes          | High   | Mitigate    |
| 4         | Phishing y robo de credenciales           | Medium | Mitigate    |
| 5         | Interrupción de los sistemas clínicos     | Medium | Mitigate    |

### Planes de acción

Se registraron cuatro proyectos de tratamiento en SimpleRisk. Tres de ellos están asociados a riesgos de nivel High, cumpliendo el requisito de priorizar al menos tres planes sobre riesgos de alta prioridad.

| Plan    | Objetivo                         | Fecha      | Estado       |
|---------|----------------------------------|------------|--------------|
| PLAN-01 | Recuperación ante Ransomware     | 30/10/2026 | 0% — inicial |
| PLAN-02 | Protección de historias clínicas | 30/10/2026 | 0% — inicial |
| PLAN-04 | Protección de datos de pacientes | 30/10/2026 | 0% — inicial |
| PLAN-03 | Gestión de proveedores           | 22/10/2026 | 0% — inicial |

### Recomendaciones prioritarias

- **1. Ransomware:** fortalecer protección de endpoints, actualización de sistemas, segmentación de red, mínimo privilegio y copias de seguridad aisladas.
- **2. Historias clínicas:** revisar periódicamente permisos, fortalecer autenticación y aplicar mínimo privilegio.
- **3. Datos de pacientes:** reforzar controles de acceso, monitoreo, registro de actividades y protección de información sensible.
- **4. Concientización:** capacitar al personal y fortalecer los controles frente a phishing.
- **5. Continuidad:** establecer procedimientos de contingencia, redundancia y pruebas periódicas de restauración.

### Conclusión

La evaluación permite establecer prioridades concretas para reducir la exposición de la clínica. La dirección debería concentrar inicialmente los recursos en ransomware, protección de historias clínicas y protección de datos de pacientes, manteniendo seguimiento sobre los restantes riesgos mediante los planes de tratamiento definidos en SimpleRisk.